Graphical Abstract

Cream Skimming the Underground: Identifying Relevant Points in TI Feeds and Online Forums

Kajal Patel, Mateus Nogueira, Zubair Shafiq, Enrico Lovat, Taimur Kashif, Ashton Woiwood, Matheus Martins, Felipe Moreno-Vera, Miguel Bicudo, Cainã Figueiredo, Cabral Lima, Gaurav Srivastava, Anton Kocheturov, Leandro Pfleger de Aguiar, Daniel Menasché

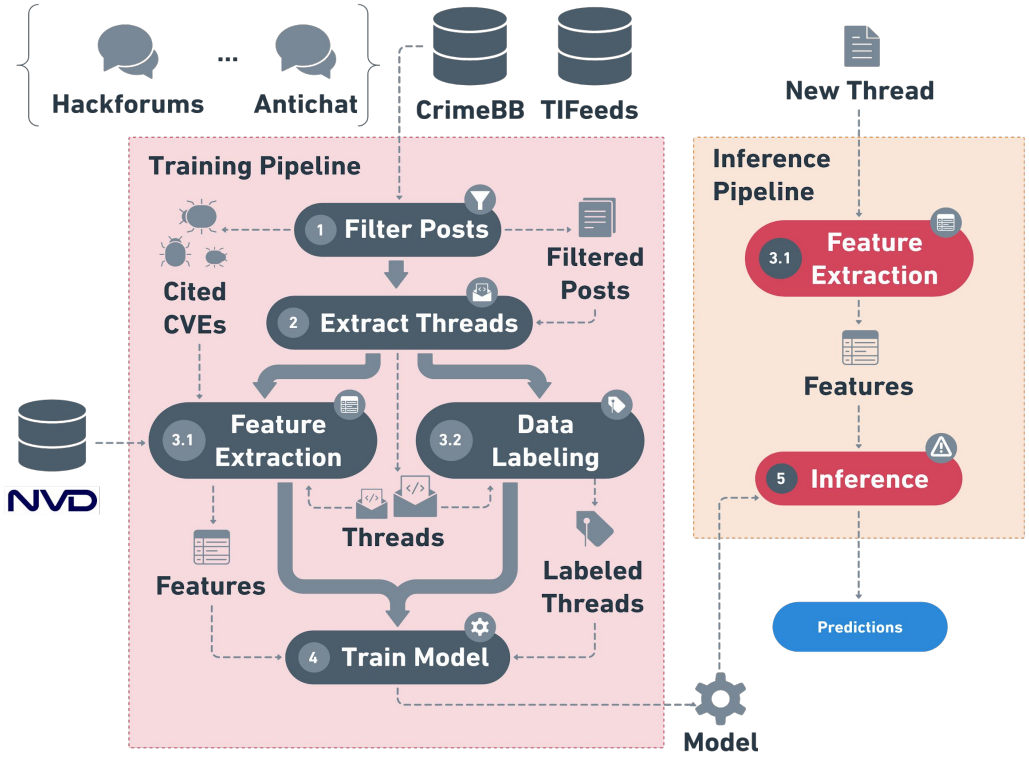


Figure 1: Main pipeline used to extract and process textual information from datasets such as CrimeBB, TIFeeds, NVD, etc. Then train a classifier to identify and predict potential threats from the textual content of the data.

Highlights

Cream Skimming the Underground: Identifying Relevant Points in TI Feeds and Online Forums

Kajal Patel, Mateus Nogueira, Zubair Shafiq, Enrico Lovat, Taimur Kashif, Ashton Woiwood, Matheus Martins, Felipe Moreno-Vera, Miguel Bicudo, Cainã Figueiredo, Cabral Lima, Gaurav Srivastava, Anton Kocheturov, Leandro Pfleger de Aguiar, Daniel Menasché

- A single NLP pipeline flags exploitation evidence in TI feeds and underground forums.
- Attention-head analysis shows how fine-tuning refocuses BERT on threat-specific terms.
- Forum threads citing CVEs are classified as PoC, weaponization, or exploitation.
- A side-by-side comparison of TI feeds and forums guides source-specific design choices.

NEXRES 14 (2026) 102526

Contents lists available at ScienceDirect

Next Research

journal homepage: www.elsevier.com/locate/nexres

Research Paper

Cream skimming the underground: Identifying relevant points in TI feeds and online forums

Kajal Patel[a], Mateus Nogueira[b], Zubair Shafiq[a], Enrico Lovat[c], Taimur Kashif[a], Ashton Woiwood[d], Matheus Martins[e], Felipe Moreno-Vera[f], Miguel Bicudo[b], Cainã Figueiredo[b], Cabral Lima[b], Gaurav Srivastava[c], Anton Kocheturov[c], Leandro Pfleger de Aguiar[c], Daniel Menasché[b,*]

[a] University of California, Davis, CA, United States
[b] Federal University of Rio de Janeiro, Rio de Janeiro, RJ, Brazil
[c] Siemens, Princeton, NJ, United States
[d] University of Iowa, Iowa City, IA, United States
[e] Siemens, Amadora, LX, Portugal
[f] Getulio Vargas Foundation, Rio de Janeiro, RJ, Brazil

ARTICLE INFO

Keywords:
Threat intelligence
Software vulnerability
Risk assessment
Underground forums
Natural language processing

ABSTRACT

Security teams turn to Threat Intelligence (TI) feeds and underground forums to anticipate emerging risks, yet both sources consist largely of free-form text that analysts cannot triage by hand at scale. We study how natural language processing can surface the items in these sources that matter most for vulnerability risk assessment: evidence that a vulnerability is being exploited in the wild, together with earlier lifecycle signals such as proofs of concept and weaponization. We place TI feeds and underground forums within a single classification framework and focus on three contributions. First, we present a unified pipeline and a side-by-side comparison of TI feeds and underground forums, covering their structure, the way labels can be obtained for each, and how different text representations behave on them. Second, we analyze the attention heads of TIBERT, a BERT model fine-tuned on TI text, and show that fine-tuning shifts attention towards domain terms such as OSINT and phishing, which helps explain why domain adaptation improves detection. Third, we apply the pipeline to CVE-citing threads from black hat forums in CrimeBB, where a Random Forest over Doc2Vec features separates exploitation from non-exploitation threads with an F1 score of 0.99. Taken together, the results indicate that exploitation-relevant content can be surfaced automatically from TI feeds and underground forums, supporting data-driven, context-aware vulnerability risk assessment.

1. Introduction

Deciding which vulnerabilities to patch first hinges on a question that standard scoring systems answer only indirectly: is anyone actually exploiting this flaw right now? The Common Vulnerability Scoring System (CVSS) [1] records whether exploit code exists, and the Exploit Prediction Scoring System (EPSS) [2] forecasts the probability that a vulnerability will be exploited after disclosure, but neither observes exploitation directly. Observations of exploitation in the wild are therefore a valuable complement to both [3].

Two kinds of sources routinely carry such observations. Threat Intelligence (TI) feeds are curated streams of Indicators of Compromise (IoCs)—IP addresses, domains, file hashes—accompanied by analyst notes, and are increasingly exchanged through platforms and standards such as MISP [4] and STIX [5]. Underground (black hat) forums, in turn, host discussions in which participants advertise, request, and trade exploits [6,7]. The two sources differ in authorship and structure, but they share a practical obstacle: the information that matters is buried in free text, and it arrives in volumes and styles that make manual reading infeasible. Exchange formats standardize the envelope of a TI event, not

* Corresponding author.
E-mail addresses: kajpatel@ucdavis.edu (K. Patel), msznogueira@gmail.com (M. Nogueira), zshafiq@ucdavis.edu (Z. Shafiq), enrico.lovat@siemens.com (E. Lovat), tkashif@ucdavis.edu (T. Kashif), awoiwood1@gmail.com (A. Woiwood), matheus.martins@siemens.com (M. Martins), felipe.moreno.vera@gmail.com (F. Moreno-Vera), masbicudo@gmail.com (M. Bicudo), cainafpereira@cos.ufrj.br (C. Figueiredo), cabrallimabrazil@gmail.com (C. Lima), srivastava.gaurav@siemens.com (G. Srivastava), anton.kocheturov@siemens.com (A. Kocheturov), lpaguiar@gmail.com (L. Pfleger de Aguiar), sadoc@dcc.ufrj.br (D. Menasché).

https://doi.org/10.1016/j.nexres.2026.102526
Received 25 June 2026; Received in revised form 29 September 2026; Accepted 1 October 2026
Available online 15 October 2026
3050-4759/© 2026 Published by Elsevier Ltd.

the prose inside it, and forum posts have no envelope at all. An example of a TI event is shown in Appendix A.

In earlier conference papers we tackled each source separately. For TI feeds [8], we characterized 191 feeds and showed that domain-adapted embeddings—TI2Vec, derived from Doc2Vec [9], and TIBERT, derived from BERT [10]—detect exploitation events under temporal and temporal + spatial evaluation. For forums [11–13], we classified CrimeBB threads that cite CVE identifiers according to the lifecycle stage they discuss. Three questions were left open: whether a single methodology serves both sources, which properties of each source shape the design of that methodology, and why fine-tuning a language model on TI text improves detection in the first place.

This article addresses these questions. Its contributions are as follows.

1. **A unified framework.** We cast exploitation detection in TI feeds and lifecycle classification in forums as instances of a single pipeline (Fig. 1) and compare the two sources side by side in terms of unit of analysis, availability of structured metadata, labeling strategy, and behavior of text representations (Sections 2, 3, and 6).
2. **Interpretability of TIBERT.** Using attention-head visualizations, we show how fine-tuning shifts BERT's attention towards terms characteristic of TI reporting, such as OSINT and phishing, offering an explanation for the gains of domain adaptation (Section 4.2).
3. **Forum classification within the framework.** We apply the pipeline to CVE-citing threads from CrimeBB [6], distinguishing proof-of-concept, weaponization, and exploitation discussions, and contrast the maturity of CrimeBB activity with that of a curated Russian market [7] (Section 5).
4. **Cross-source implications.** We discuss how signals from the two sources can feed CVSS- and EPSS-based risk assessment, and which differences in data and evaluation prevent a direct comparison of their scores (Section 6).

Relation to prior publications. The characterization of TI feeds, the labeling procedure, and the temporal, temporal + spatial, and feature-ablation results for TI feeds were published in [8]. In this article they are summarized in Sections 2, 3, and 4.1 (see also Supplementary Material for details). The forum pipeline builds on [11–13]. The unified treatment, the attention-head analysis, and the cross-source discussion are new to this article.

Paper organization. Section 2 introduces the two data sources and contrasts them. Section 3 describes the unified pipeline. Section 4 summarizes the TI-feed results and presents the attention-head analysis, and Section 5 reports the forum results. Section 6 discusses lessons across sources, Section 7 reviews related work, and Section 8 concludes.

2. Data sources

2.1. Threat intelligence feeds

Our TI corpus combines the public feeds that ship with MISP [14] with feeds obtained from Cyber Threat Intelligence communities whose sharing rules follow the Traffic Light Protocol (TLP) [15]. We retain only events marked *tlp:white*, i.e., publicly shareable, and replace provider names with anonymous identifiers (Feed 1, Feed 2, …), which keeps the study reproducible without breaching non-disclosure agreements. As a feed may aggregate events from several contributors, we use the terms feed and provider interchangeably.

The corpus contains 191 feeds, roughly 14 thousand events, and 866,541 IoCs spanning 2013–2019. An event describes an incident (e.g., a phishing or botnet campaign) or an advisory. It groups a set of *attributes*—IoCs with a category, a timestamp, and an optional free-text comment—and is annotated with *tags* drawn from standardized MISP taxonomies [16].

Our conference paper [8] characterized this corpus in detail. Three findings are relevant here:

Table 1
Statistics about considered forums. Forums are divided into boards, and boards are divided into threads. Each thread contains a list of posts (Ranked by the number of threads).

Forum	#Boards	#Threads	#Posts	#Users
Hackforums	195	3 978 765	41 568 806	614 947
MPGH	731	767 290	9 363 407	475 942
Antichat	61	237 947	2 449 268	79 744
Offensive Community	71	119 236	127 104	11 508
DREADditevelidot	446	74 867	294 596	43 115
RaidForums	71	34 645	214 855	44 639
Runion	19	16 866	236 483	17 255
Safe Sky Hacks	50	12 963	27 018	7441
The-Hub	62	11 286	86 251	8314
Torum	11	4 321	26 958	3817
Germany Ruvvy	38	4 068	20 179	2515
Kernelmode Forum	11	3 439	19 053	1520
Garage4hackers	35	2 093	7 697	880
Greysec	25	1 639	9 228	722
Stresser Forum	17	708	7 069	764
Envoy Forum	91	454	2 162	362
Total	1 934	5 270 587	54 460 134	1 313 485

Table 2
Black hat forums vs TI feeds.

	Black hat forums	TI feeds
Basic elements	posts	attributes (e.g., IoCs)
Structured features	not available	tags
Unstructured features	text of posts	free textual description of events
Groups of basic elements, i.e., instances for ML training and classification	groups of posts with same subject, i.e., threads	TI feed events
Source	CrimeBB (10 forums)	MISP (187 organizations)

- *Skewed volume.* The largest feed alone contributes 276,481 IoCs, and average event sizes range from fewer than ten to more than a thousand IoCs per feed, although most events in every feed are small.
- *Text-rich content.* Network activity (557,532 IoCs), payload delivery (220,321), and external analysis (38,531) account for 87% of all IoCs, and about two thirds of IoCs carry an analyst comment.
- *Dynamic, partly redundant feeds.* Events are updated over periods ranging from minutes to months, and IoC overlap between feeds is uneven: some feeds mostly publish IoCs first (*sources*), whereas others mostly repeat IoCs seen elsewhere (*sinks*).

These properties motivate automated methods that read the free text of events and that are evaluated with explicit temporal and cross-feed constraints.

2.2. Underground forums

For forums we use CrimeBB, a collection of underground forums scraped and curated by the Cambridge Cybercrime Center [6]. Forums are organized into boards, boards into threads, and threads into posts; Table 1 summarizes the forums considered. Because our interest lies in vulnerability exploitation, we keep threads in which at least one post cites a Common Vulnerabilities and Exposures (CVE) identifier. This yields about 1068 threads with 46,809 posts, a volume comparable to earlier studies of exploit markets [17,18].

2.3. Comparing the two sources

Table 2 places the two sources side by side. In both, the instance to classify is a group of textual elements: an event made of attributes in TI feeds, and a thread made of posts in forums. Both expose their

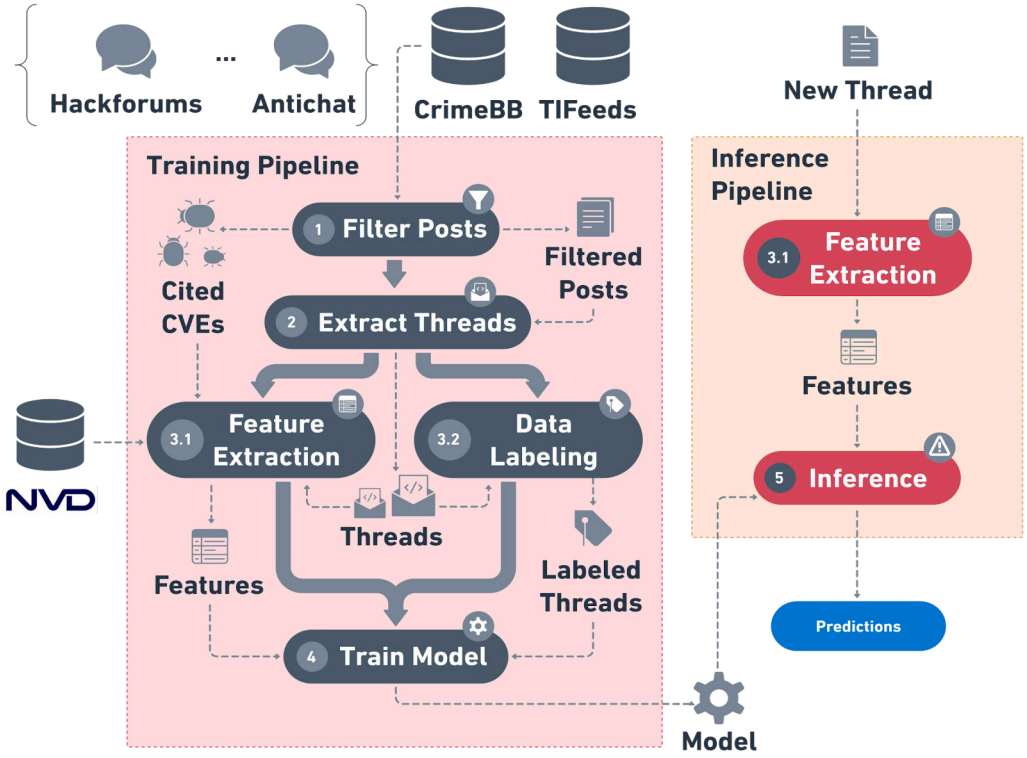


Fig. 1. Unified pipeline: (1) Training pipeline, comprising pre-processing of events or threads, feature extraction, and labeling; (2) Prediction pipeline, in which a classifier assigns a label to each new event or thread based on its content.

key content as unstructured text. They differ, however, in the metadata available around that text. TI events carry analyst-assigned taxonomy tags that can be exploited for labeling, while forum threads offer no comparable structured field. They also differ in authorship: TI text is written by security analysts for defenders, whereas forum text is written by participants of widely varying expertise, often for other attackers. Section 6 returns to how these differences shape the pipeline and the interpretation of its results.

3. A unified classification pipeline

Fig. 1 outlines the pipeline shared by both sources. Textual instances are filtered, pre-processed, encoded into vectors, and passed to a supervised classifier trained on labeled data. The components specific to TI feeds were introduced in [8] and those specific to forums in [11]; we summarize them here and defer full details to Supplementary Material Section S2.

3.1. Classification tasks

We distinguish three stages of the vulnerability lifecycle. A *proof of concept* (PoC) demonstrates that a flaw can be triggered; *weaponization* means that a working exploit exists, which can be established in a controlled setting [19–21]; and *exploitation* means that the exploit has been observed in use in the wild. For TI feeds, the task is binary: decide whether an event reports exploitation. For forums, where discussions frequently concern earlier stages, we consider a three-class task (PoC, weaponization, exploitation) and the corresponding one-vs-rest binary tasks.

3.2. Labels

TI feeds. We start from events whose text or attributes mention a CVE identifier. Two experts labeled them following a code book: an event is labeled exploitation when it contains a clearly malicious element (e.g., an APT, a DDoS, or a trojan), belongs to a known campaign, names a known threat group, or uses terms such as espionage or campaign in a malicious context; it is labeled non-exploitation when it describes a benign update or patch, lacks evidence of malicious activity, or is too ambiguous. On a 10% subset labeled by both experts, Cohen's kappa [22] was 0.89, indicating strong agreement. This yielded about four thousand labeled events. To label the remaining events, we mined association rules between event tags and the exploitation label with the apriori algorithm [23] (support ≥ 0.001, confidence ≥ 0.5, lift ≥ 1), obtaining roughly 735 rules, and labeled an event as exploitation whenever its tags matched every tag of some rule. Overall, 18% of events are labeled exploitation. The complete code book, rule examples, and per-feed label distribution appear in Supplementary Material Section S2.

Forums. Threads citing CVE identifiers are extracted with regular expressions and labeled as PoC, weaponization, or exploitation following the procedure of [11]. Unlike TI events, forum threads carry no tags, so rule-based label propagation is not available.

3.3. Text representations

Before encoding, text is split on special characters and stop words are removed. File hashes, which are largely unique to individual feeds and therefore do not transfer across them, are replaced by a single placeholder token.

For TI feeds we compare static and contextual embeddings. *Doc2Vec* [9] assigns each word a single vector regardless of context; *TI2Vec* is a Doc2Vec model trained without supervision on our 191-feed corpus for 15 epochs. *BERT* [10] (BERT-base-uncased, served through BERT-as-Service [24]) produces 768-dimensional contextual representations of text split into WordPiece sub-word tokens; *TIBERT* is obtained by fine-tuning BERT-base-uncased with a sequence classification head on our labeled TI data for 10 epochs. For forums, we use bag-of-words (BoW), TF-IDF, and Doc2Vec encodings [11].

3.4. Classifiers and evaluation protocols

For TI feeds, Doc2Vec, TI2Vec, and BERT features feed Naive Bayes, Decision Tree, and AdaBoost classifiers, whereas TIBERT classifies events with its own head, learning representation and decision jointly. Because exploitation is an evolving phenomenon, we evaluate with *temporal* splits: the data are divided into 11 consecutive windows of equal size and each window is tested with a model trained either on the preceding window only (*equal window*) or on all preceding windows (*aggregate window*). In *temporal + spatial* splits, one feed is additionally held out from training and used as the sole test feed, which measures transfer to unseen feeds. For forums, we train Decision Trees and Random Forests on the three encodings. Given the class imbalance of the TI data (82% non-exploitation), we report F1 scores throughout.

4. Exploitation detection in TI feeds

4.1. Summary of previously reported results

The quantitative evaluation of the TI-feed pipeline was published in [8]; its tables and figures, including per-split results, per-feed transfer results, and feature ablation, are reproduced in Supplementary Material Section S3. In brief, averaged over temporal splits, F1 scores range from 0.56 to 0.78 depending on the representation and classifier. Domain adaptation pays off for both families of embeddings: TI2Vec outperforms Doc2Vec, and TIBERT outperforms BERT, reaching the best average F1 of 0.78 under equal-window splits, about four percentage points above TI2Vec. Training on the most recent window yields better results than accumulating all past windows (0.78 vs. 0.63 for TIBERT), suggesting that recency matters more than volume. When a feed is held out, transfer works best for feeds that mostly repeat IoCs published elsewhere (e.g., F1 of 0.89 for Feed 6) and worst for feeds that mostly originate them (0.45 for Feed 1). Finally, combining all IoC categories outperforms any single category. A two-dimensional t-SNE view of the static embeddings, showing that TI2Vec separates the two classes more clearly than Doc2Vec, is given in Supplementary Material Section S4. The remainder of this section asks *why* domain adaptation helps the contextual model.

4.2. Why does domain adaptation help? Attention in BERT and TIBERT

We examine what fine-tuning changes inside the model through BERT's attention mechanism [25]. BERT maps a sequence of tokens, here a fragment of an event description, to contextual vectors through 12 stacked layers, each containing 12 attention heads. Head k of layer l defines a matrix $\alpha^{(k,l)}$ whose entry $\alpha_{i,j}^{(k,l)}$ quantifies how strongly token i draws on token j when its representation is computed. The larger this weight, the more the joint presence of the two tokens influences the embedding that BERT outputs.

Figs. 2 and 3 display these weights with BertViz [25]. The darkness of the line connecting tokens i and j is proportional to $\sum_{k=1}^{12} \alpha_{i,j}^{(k,l)}$, the attention accumulated over the heads of layer l; links with very small weights are not visible. The colored bars next to each token show the contribution of each of the 12 heads, with intensity proportional to $\alpha_{i,j}^{(k,l)}$. Fig. 2 shows TIBERT on two sentences taken from exploitation events, one from the *external analysis* category (layer 3) and one from the *network activity* category (layer 1); Fig. 3 shows the pre-trained model on the same inputs. Note that WordPiece splits both "OSINT" and "phishing" into two sub-word tokens.

Two observations stand out. First, in the sentence containing "look into recent exploit kit activities" (panel (a) of both figures), the tokens 'exploit', 'kit', and 'activities' are strongly linked before and after fine-tuning, indicating that the pre-trained model already captures some generic co-occurrences that are relevant to the task. After fine-tuning, however, the sub-word tokens of OSINT also receive substantial attention, which they do not in the pre-trained model. Second, in the network activity sentence (panel (b)), 'phishing' becomes a prominent attention target only after fine-tuning. The same term also stands out in the word clouds of exploitation events (Supplementary Material Section S2), consistent with its discriminative role. In this sentence, the strong weight between 'activity' and the separator token [SEP] reflects a known behavior of BERT attention [26] rather than domain adaptation.

In the pre-trained model, neither OSINT nor phishing was emphasized by any head in any layer for these inputs; after fine-tuning, both were. This suggests a simple account of the gains of TIBERT: fine-tuning preserves the co-occurrence patterns learned during pre-training and adds patterns specific to TI reporting, yielding embeddings in which exploitation and non-exploitation events are easier to separate. We stress that this analysis is qualitative and based on selected sentences, and that attention weights are not by themselves complete explanations of model decisions; a systematic, quantitative study of attention shifts across the corpus is left for future work.

5. Online black hat forums

We now apply the pipeline to CrimeBB, building on our earlier forum studies [11–13]. The purpose is twofold: to show that the same design identifies relevant information points in a very different kind of unstructured feed, and to expose the similarities and differences between forums and TI feeds.

As the volume of posts discussing vulnerabilities grows, a filter that raises alarms depending on thread content becomes necessary. We therefore train supervised models on the CVE-citing threads described in Section 2.2, encoding post content with BoW, TF-IDF, and Doc2Vec, and address two tasks: (task 1) assign each thread one of the three labels PoC, weaponization, or exploitation; and (task 2) separate exploitation from non-exploitation threads, together with the analogous one-vs-rest tasks for PoC and weaponization.

Table 3 reports the results. Random Forests outperform Decision Trees by roughly ten percentage points on both tasks, at the cost of interpretability. For the three-class task, Random Forest F1 scores lie between 0.84 and 0.86 depending on the encoding. Separating exploitation from non-exploitation threads is the easiest task, with F1 reaching 0.99 for Random Forests over Doc2Vec, whereas weaponization is the hardest, with F1 of at most 0.69.

To place CrimeBB activity in context, we compare it with the Russian underground market studied in [7]. Prices of offered artifacts in CrimeBB have a minimum, median, and maximum of 1, 100, and 4,400 USD, against 100, 2,000, and 8,000 USD in the Russian market. Access to the Russian market is controlled by its administrators, which tends to make its discussions more mature. The age of posts, measured relative to the publication date of the cited CVE in the National Vulnerability Database (NVD), points in the same direction: CrimeBB posts tend to be more recent than those in the Russian market. Both observations indicate that CrimeBB content is less mature and noisier on average, reinforcing the need for automated filtering before analysts inspect it.

6. Discussion: lessons across sources

6.1. What carries over, and what does not

The same stages—filter, encode, classify—apply to both sources, but three differences affect how each stage should be instantiated.

Supervision. Taxonomy tags made it possible to grow a few thousand expert labels into labels for the whole TI corpus through association rules. Forum threads offer no such metadata, so labels must be obtained directly, and the CVE filter doubles as both a relevance filter and an anchor for labeling, which limits the labeled set to about one thousand threads versus roughly 14 thousand TI events. Tag-free text classifiers are thus the only option in forums; in TI feeds they remain valuable for untagged feeds and for acting on events before analysts tag them.

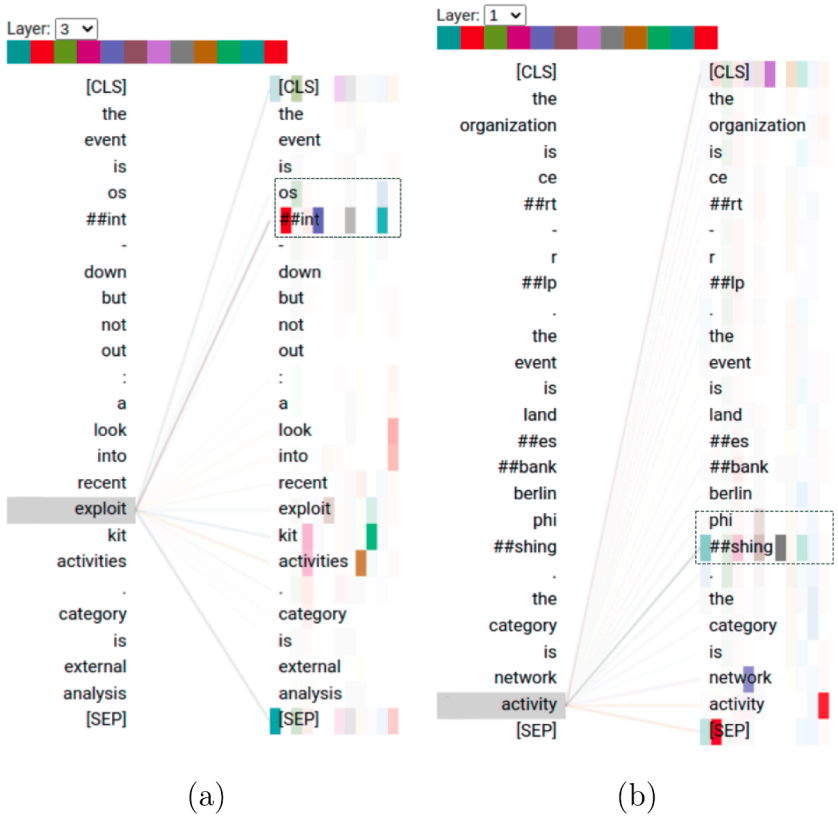


Fig. 2. Attention weights of TIBERT, i.e., after fine-tuning, visualized with BertViz [25]: (a) Layer 3, sentence from the *external analysis* category; (b) Layer 1, sentence from the *network activity* category. Both sentences come from exploitation events.

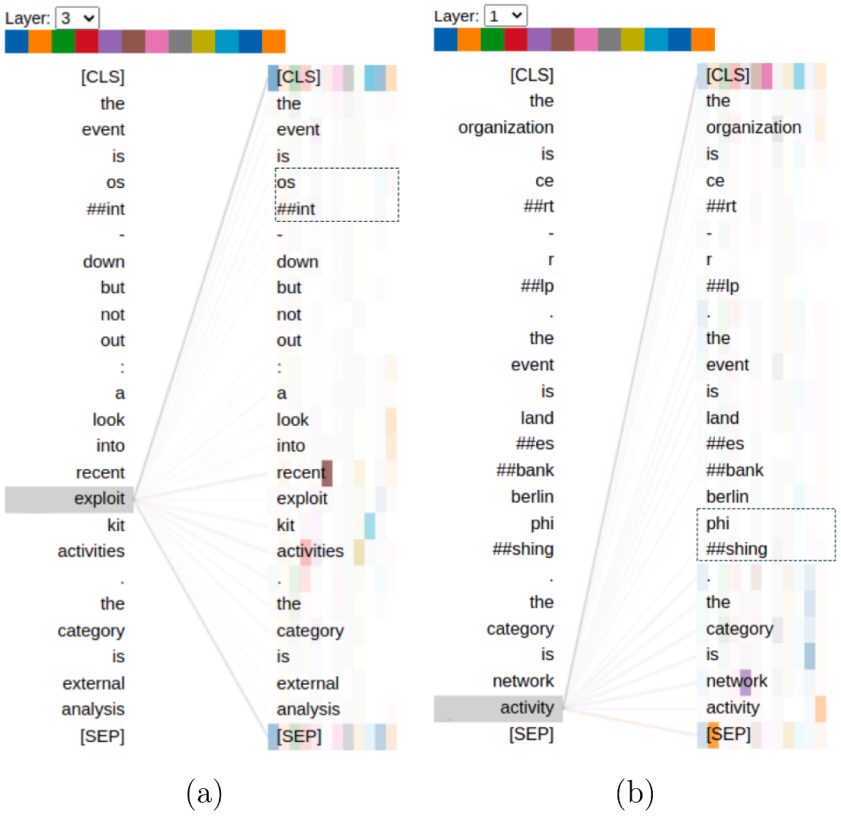


Fig. 3. Attention weights of the pre-trained BERT model, i.e., before fine-tuning, for the same sentences and layers as in Fig. 2(a) and (b), respectively.

Table 3
Decision Tree (DT) and Random Forest (RF) performance for classification of threads in online forums.

	Text encoding	Target classes	Accuracy	Precision	Recall	F1
DT	BoW	PoC, Weaponization, Exploitation	0.71	0.71	0.72	0.70
DT	TF-IDF	PoC, Weaponization, Exploitation	0.73	0.73	0.74	0.72
DT	Doc2Vec	PoC, Weaponization, Exploitation	0.74	0.74	0.74	0.73
DT	BoW	Exploitation vs Non-exploitation	0.85	0.86	0.85	0.85
DT	TF-IDF	Exploitation vs Non-exploitation	0.91	0.91	0.91	0.91
DT	Doc2Vec	Exploitation vs Non-exploitation	**0.92**	**0.93**	**0.92**	**0.92**
DT	BoW	PoC vs Non-PoC	0.75	0.75	0.75	0.75
DT	TF-IDF	PoC vs Non-PoC	0.77	0.78	0.77	0.77
DT	Doc2Vec	PoC vs Non-PoC	0.70	0.71	0.70	0.70
DT	BoW	Weaponization vs Non-weapon.	0.68	0.68	0.68	0.68
DT	TF-IDF	Weaponization vs Non-weapon.	0.63	0.64	0.63	0.62
DT	Doc2Vec	Weaponization vs Non-weapon.	0.59	0.59	0.59	0.59
RF	BoW	PoC, Weaponization, Exploitation	0.85	0.84	0.85	0.84
RF	TF-IDF	PoC, Weaponization, Exploitation	0.86	0.87	0.86	0.86
RF	Doc2Vec	PoC, Weaponization, Exploitation	0.86	0.90	0.86	0.86
RF	BoW	Exploitation vs Non-exploitation	0.98	0.98	0.98	0.98
RF	TF-IDF	Exploitation vs Non-exploitation	0.98	0.98	0.98	0.98
RF	Doc2Vec	Exploitation vs Non-exploitation	**0.99**	**0.99**	**0.99**	**0.99**
RF	BoW	PoC vs Non-PoC	0.84	0.84	0.84	0.84
RF	TF-IDF	PoC vs Non-PoC	0.87	0.87	0.87	0.87
RF	Doc2Vec	PoC vs Non-PoC	0.88	0.90	0.88	0.87
RF	BoW	Weaponization vs Non-weapon.	0.67	0.67	0.67	0.67
RF	TF-IDF	Weaponization vs Non-weapon.	0.69	0.70	0.69	0.69
RF	Doc2Vec	Weaponization vs Non-weapon.	0.58	0.58	0.58	0.58

Representations. In TI feeds, domain adaptation helps consistently: TI2Vec improves on Doc2Vec and TIBERT on BERT, and Section 4.2 offers a mechanism for the latter. In forums, no single encoding dominates. Doc2Vec yields the best results for separating exploitation from non-exploitation but the worst for separating weaponization from the other classes (F1 of 0.58 versus 0.69 for TF-IDF with Random Forests). The choice of representation should therefore depend on the lifecycle stage of interest. Weaponization, which sits between proof of concept and exploitation, is the hardest stage to isolate regardless of classifier. Forum-adapted embeddings analogous to TI2Vec and TIBERT are a natural next step.

Authorship and maturity. TI text is written by analysts using a fairly stable vocabulary, whereas forum text is written by participants of heterogeneous expertise, and the comparison with a curated market (Section 5) suggests that much of it is immature. Relevance filtering is correspondingly more important in forums.

Evaluation. The TI results were obtained under temporal and temporal + spatial splits designed to mimic deployment, whereas the forum results in Table 3 follow the protocol of [11]. The absolute scores are therefore not directly comparable, and the higher forum scores should not be read as evidence that forums are an easier source. Evaluating forum classifiers under temporal and cross-forum splits, analogous to the cross-feed splits used for TI feeds, is part of our future work.

6.2. Implications for vulnerability risk assessment

The two sources cover complementary parts of the vulnerability lifecycle. Forums surface discussions of proofs of concept and weaponization, often close to disclosure, while TI feeds report analyst-curated activity in the wild [27]. Exploitation detected in either source can serve as evidence when revising the temporal metrics of CVSS, for instance raising Exploit Code Maturity from proof of concept to functional exploit, and as ground-truth observations for calibrating exploitation predictors such as EPSS. Because our classifiers operate on events and threads rather than on CVE identifiers, and only a fraction of TI events cite CVEs explicitly, linking detections to specific vulnerabilities remains a necessary step. Classification errors carry operational costs: false positives may trigger unnecessary emergency patching, and false negatives may delay remediation. As the detections are intended to adjust existing scores rather than replace them, their impact is bounded; a more detailed discussion of these trade-offs for TIBERT is provided in Supplementary Material Section S3.

6.3. Limitations

The TI corpus covers 2013–2019 and only publicly shareable events, so vocabulary and threat landscape may have shifted since. Beyond the expert-labeled seed, TI labels derive from analyst-assigned tags and may inherit tagging biases. The forum analysis is restricted to threads that cite CVE identifiers and therefore misses exploitation discussed without them. Finally, the attention analysis is qualitative, as noted in Section 4.2.

7. Related work

Measuring TI feeds. Early studies evaluated feeds that target specific threats, such as phishing URL blacklists [28], spam feeds [29], and IP blocklists [30,31], and found large differences in coverage, freshness, and bias. Later work examined broader collections [32] and the benefits of combining feeds [31,33]; surveys summarize these findings [34]. We analyze general-purpose feeds as well, but instead of rating their quality we extract a specific signal, exploitation, from their text.

Predicting vulnerability lifecycles. Numerous works predict lifecycle stages such as discovery, weaponization, exploitation, and patching [35–42] and feed models such as EPSS and CVSS [43, 44]. Social media [37,45], darknet forums combined with other sources [38,42], Shodan scans [39], spam feeds combined with patch measurements [40], and TI feeds describing malware campaigns [41] have all been used for this purpose. These approaches

are vulnerability-oriented and typically require a CVE identifier [46], whereas our TI classifiers operate on events, most of which do not cite CVEs.

Underground forums and markets. CrimeBB [6] has enabled many studies of underground communities, and exploit markets have been analyzed in terms of their economics, offers, and prices [7,17,18]. Our earlier work classified CVE-citing CrimeBB threads by lifecycle stage [11–13]. This article connects that line of work with TI-feed analysis within a common framework.

8. Conclusion & future work

This article brought exploitation detection in TI feeds and lifecycle classification in underground forums into a single NLP framework. Summarizing our prior TI-feed results, domain-adapted embeddings outperform generic ones, with TIBERT reaching an average F1 of 0.78 under temporal evaluation. The new attention-head analysis suggests why: fine-tuning adds attention to terms typical of TI reporting, such as OSINT and phishing, on top of the generic co-occurrences captured during pretraining. Applied to CrimeBB, the pipeline separates exploitation from non-exploitation threads with high accuracy, while weaponization remains the hardest stage to isolate. Comparing the two sources showed that differences in metadata, authorship, and evaluation protocol shape how the pipeline should be instantiated and how its scores should be read.

Several directions remain open. Forum-specific domain adaptation and temporal, cross-forum evaluation would bring the forum analysis on par with the TI-feed analysis. Larger and more recent TI corpora would broaden vocabulary coverage. A quantitative study of attention shifts would put the interpretability findings on firmer ground. Finally, linking detections to CVE identifiers would allow detected exploitation, weaponization, and patching activity to feed directly into CVSS- and EPSS-based risk assessment.

CRediT authorship contribution statement

Kajal Patel: Software, Formal analysis; **Mateus Nogueira:** Software, Conceptualization; **Zubair Shafiq:** Writing – original draft, Supervision, Software, Methodology, Funding acquisition; **Enrico Lovat:** Funding acquisition, Formal analysis; **Taimur Kashif:** Software, Methodology, Investigation; **Ashton Woiwood:** Software, Methodology; **Matheus Martins:** Writing – review & editing, Writing – original draft, Software; **Felipe Moreno-Vera:** Writing – review & editing, Writing – original draft, Software, Investigation, Data curation; **Miguel Bicudo:** Writing – original draft, Software, Investigation, Data curation, Conceptualization; **Cainã Figueiredo:** Writing – review & editing, Writing – original draft, Software, Investigation, Data curation; **Cabral Lima:** Project administration; **Gaurav Srivastava:** Writing – review & editing, Resources, Funding acquisition; **Anton Kocheturov:** Writing – review & editing, Funding acquisition, Conceptualization; **Leandro Pfleger de Aguiar:** Writing – original draft, Software, Funding acquisition; **Daniel Menasché:** Writing – review & editing, Writing – original draft, Visualization, Supervision, Project administration, Formal analysis, Conceptualization.

Declaration of competing interest

Not applicable. There is no conflict of interests or competing interest.

Acknowledgement

This work was partially supported by CAPES, CNPq and FAPERJ under grant CNE E-26/204.268/2024.

Data availability

The data used in this study come from two main sources. The CrimeBB dataset can be requested from the Cambridge Cybercrime Center, subject to its access policies and terms of use. The threat intelligence (TI) feeds analyzed in this work were obtained from the anonymized organizations described in Appendix B. Access to these TI feeds is subject to the policies, availability conditions, and sharing restrictions defined by the corresponding providers.

Supplementary material

Supplementary material associated with this article can be found in the online version at 10.1016/j.nexres.2026.102526.

Appendix A. An example of an event

Listing A.1 shows an event describing how a command and control server is contacted by an app created by Pawn Storm, a cyber espionage campaign. The attributes include a textual description written by a security expert and a related URL. The tag “threat-actor = Sofacy” indicates ties to the Russian government. The event was manually labeled as exploitation. Only significant fields are shown.

```
{
    ``id": ``955",
    ``date": ``2015-02-04",
    ``info": ``OSINT - Pawn Storm Update: iOS Espionage App Found",
    ``attribute_count": ``10",
    ``timestamp": ``1539794378",
    ``publish_timestamp": ``1557925412",
    ``Attribute": [
        {
            ``id": ``93978",
            ``type": ``text",
            ``category": ``External analysis",
            ``event_id": ``955",
            ``timestamp": ``1539794378",
            ``comment": ``",
            ``value": ``In our continued research on Operation Pawn
            ↪  Storm, we found one interesting poisoned
            ↪  pawn\u2014spyware specifically designed for espionage
            ↪  on iOS devices...As of this publishing, the C&C server
            ↪  contacted by the iOS malware is live."
        },
        {
            ``id": ``93981",
            ``type": ``url",
            ``category": ``Network activity",
            ``event_id": ``955",
            ``timestamp": ``1539794378",
            ``comment": ``",
            ``value": ``/adhoc/XAgent.plist",
        }
    ],
    ``Tag": [
        {
            ``id": ``24",
            ``name": ``misp-galaxy:threat-actor=Sofacy"
        }
    ]
}
```


Listing A.1. An event in .json format from TI Feed 2.

Appendix B. TI feed organizations

Table B.1 summarizes the providers of the top-10 feeds. Some are national teams, whereas others are public or private corporations.

Table B.1
General description of anonymized top-10 TI feed providers.

Provider	Description
Feed 1	National Computer Emergency Response Team (CERT) of an European country
Feed 2	Computer Incident Response Center (CIRC) of an European country
Feed 3	Lists of IPs associated to malicious activities, to be blocked or filtered as reported by a threat intelligence firm
Feed 4	List of events related to malware activity as observed by a large international corporation
Feed 5	Open source intelligence gathered by an European national authority
Feed 6	National private sharing group with large private corporations as participants
Feed 7	List of indicators about the dissemination of a specific malware family by a private threat intelligence corporation
Feed 8	List of indicators about the dissemination of a specific malware family by a private threat intelligence corporation
Feed 9	International private sharing group with cybersecurity experts as participants
Feed 10	List of indicators about the dissemination of a specific malware family by a private threat intelligence corporation

References

[1] FIRST, Common vulnerability scoring system (CVSS), https://www.first.org/cvss/. Last Accessed: 2025-01-15.
[2] FIRST, Exploit prediction scoring system, https://www.first.org/epss/. Last Accessed: 2025-01-15.
[3] J. Jacobs, S. Romanosky, et al., Exploit prediction scoring system (EPSS), Digit. Threats Res. Pract. 2 (3) (2021) 1–17. https://doi.org/10.1145/3436242
[4] MISP, MISP - open source threat intelligence platform & open standards for threat information sharing, https://www.misp-project.org. Last Accessed: 2025-01-15.
[5] STIX, Introduction to STIX, (https://oasis-open.github.io/cti-documentation/stix/intro.html). Last Accessed: 2025-01-15.
[6] S. Pastrana, D.R. Thomas, et al., CrimeBB: enabling cybercrime research on underground forums at scale, in: Proceedings of the 2018 World Wide Web Conference, 2018, pp. 1845–1854. https://doi.org/10.1145/3178876.3186178
[7] L. Allodi, Economic factors of vulnerability trade and exploitation, in: Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security, 2017, pp. 1483–1499. https://doi.org/10.1145/3133956.3133960
[8] K. Patel, Z. Shafiq, M. Nogueira, D. Menasché, E. Lovat, T. Kashif, A. Woiwood, M. Martins, Harnessing TI feeds for exploitation detection, in: 2024 IEEE International Conference on Cyber Security and Resilience (CSR), IEEE, 2024, pp. 200–207. https://doi.org/10.1109/CSR61664.2024.10679417
[9] Q. Le, T. Mikolov, Distributed representations of sentences and documents, in: ICML, PMLR, 2014, pp. 1188–1196. https://doi.org/10.5555/3044805.3045025
[10] J. Devlin, M.-W. Chang, K. Lee, K. Toutanova, BERT: pre-training of deep bidirectional transformers for language understanding, in: NAACL-HLT, 2019, pp. 4171–4186. https://doi.org/10.18653/v1/N19-1423
[11] F. Moreno-Vera, M. Nogueira, C. Figueiredo, D.S. Menasché, M. Bicudo, A. Woiwood, E. Lovat, A. Kocheturov, L.P. de Aguiar, Cream skimming the underground: identifying relevant information points from online forums, in: 2023 IEEE International Conference on Cyber Security and Resilience (CSR), IEEE, 2023, pp. 66–71. https://doi.org/10.1109/CSR57506.2023.10224941
[12] F. Moreno-Vera, Inferring discussion topics about exploitation of vulnerabilities from underground hacking forums, in: 2023 14th International Conference on Information and Communication Technology Convergence (ICTC), 2023, pp. 816–821. https://doi.org/10.1109/ICTC58733.2023.10393244
[13] F. Moreno-Vera, D.S. Menasché, C. Lima, Beneath the cream: unveiling relevant information points from CrimeBB with its ground truth labels, in: International Symposium on Cyber Security, Cryptology, and Machine Learning, 2024, pp. 280–290. https://doi.org/10.1007/978-3-031-76934-4_19
[14] MISP, Default feeds, https://www.misp-project.org/feeds/. Last Accessed: 2025-01-15.
[15] FIRST. org, Traffic light protocol, https://www.first.org/tlp/. Last Accessed: 2025-01-15.
[16] MISP, MISP taxonomies and classification as machine tags, https://www.circl.lu/doc/misp-taxonomies/. Last Accessed: 2025-01-15.
[17] V. Kotov, F. Massacci, Anatomy of exploit kits: preliminary analysis of exploit kits as software artifacts, in: Engineering Secure Software and Systems, Springer, 2013, pp. 181–196. https://doi.org/10.1007/978-3-642-36563-8_13
[18] L. Allodi, F. Massacci, Comparing vulnerability severity and exploits using case-control studies, ACM TISSEC 17 (1) (2014) 1–20. https://doi.org/10.1145/2630069
[19] S. Frei, M. May, U. Fiedler, B. Plattner, Large-scale vulnerability analysis, in: SIGCOMM Workshop on Large-Scale Attack Defense, ACM, Pisa, Italy, 2006, pp. 131–138.
[20] M. Bozorgi, L.K. Saul, S. Savage, G.M. Voelker, Beyond heuristics: learning to classify vulnerabilities and predict exploits, in: KDD, ACM, Washington, DC, 2010, pp. 105–114.
[21] M. Shahzad, M.Z. Shafiq, A.X. Liu, Large scale characterization of software vulnerability life cycles, IEEE Trans. Dependable Secure Comput. 17 (4) (2019) 730–744.
[22] J. Cohen, A coefficient of agreement for nominal scales, Educ. Psychol. Meas. 20 (1) (1960) 37–46.
[23] R. Srikant, Fast Algorithms for Mining Association Rules and Sequential Patterns, The University of Wisconsin-Madison, 1996. https://doi.org/10.5555/924822
[24] H. Xiao, Bert-as-service, 2018, https://pypi.org/project/bert-serving-server/. Last Accessed: 2025-03-15.
[25] J. Vig, A multiscale visualization of attention in the transformer model, in: Proceedings of the 57th Annual Meeting of the Association for Computational Linguistics: System Demonstrations, Association for Computer Linguistics, 2019, pp. 37–42. https://doi.org/10.18653/v1/P19-3007
[26] K. Clark, U. Khandelwal, O. Levy, C.D. Manning, What does BERT look at? An analysis of BERT's attention, in: Proceedings of the 2019 ACL Workshop BlackboxNLP: Analyzing and Interpreting Neural Networks for NLP, 2019, pp. 276–286. https://doi.org/10.18653/v1/W19-4828
[27] B. Tostes, L. Ventura, E. Lovat, M. Martins, D. Menasche, Learning when to say goodbye: what should be the shelf life of an indicator of compromise?, in: 2023 IEEE International Conference on Cyber Security and Resilience (CSR), IEEE, 2023, pp. 503–510.
[28] S. Sheng, B. Wardman, G. Warner, L. Cranor, J.H.C. Zhang, An empirical analysis of phishing blacklists, in: Conference on Email and Anti-Spam (CEAS), 2009.
[29] A. Pitsillidis, C. Kanich, G.M. Voelker, K. Levchenko, S. Savage, Taster's choice: a comparative analysis of spam feeds, in: IMC, ACM, Boston, MA, 2012, pp. 427–440. https://doi.org/10.1145/2398776.2398821
[30] Á. Feal, P. Vallina, J. Gamba, S. Pastrana, A. Nappa, O. Hohlfeld, N. Vallina-Rodriguez, J. Tapiador, Blocklist babel: on the transparency and dynamics of open source blocklisting, IEEE Trans. Netw. Serv. Manage. 18 (2) (2021) 1334–1349. https://doi.org/10.1109/TNSM.2021.3075552
[31] S. Ramanathan, J. Mirkovic, M. Yu, BLAG: improving the accuracy of blacklists, in: NDSS, Internet Society, San Diego, CA, 2020, pp. 1–15.
[32] V.G. Li, M. Dunn, et al., Reading the tea leaves: a comparative analysis of threat intelligence, in: USENIX Security, USENIX, Santa Clara, 2019, pp. 851–867. https://doi.org/10.5555/3361338.3361398
[33] X. Bouwman, V.L. Pochat, P. Foremski, T.V. Goethem, C. Hernandez-Ganan, et al., Helping hands: measuring the impact of a large threat intelligence sharing community, in: USENIX Security 22, USENIX Association, Boston, MA, 2022.
[34] W. Tounsi, H. Rais, A survey on technical threat intelligence in the age of sophisticated cyber attacks, Comput. Secur. 72 (2018) 212–233. https://doi.org/10.1016/j.cose.2017.09.001
[35] A.D. Householder, J. Chrabaszcz, et al., Historical analysis of exploit availability timelines, in: CSET, 2020. https://doi.org/10.5555/3485754.3485760
[36] J. Yin, M. Tang, et al., Vulnerability exploitation time prediction: an integrated framework for dynamic imbalanced learning, World Wide Web 25 (1) (2022) 401–423.
[37] C. Sabottke, et al., Vulnerability disclosure in the age of social media: exploiting twitter for predicting real-world exploits, in: 24th USENIX Security Symposium (USENIX Security 15), 2015. https://doi.org/10.5555/2831143.2831209
[38] M. Almukaynizi, E. Nunes, et al., Proactive identification of exploits in the wild through vulnerability mentions online, in: CyCon, NATO, Tallinn, 2017, pp. 82–88. https://doi.org/10.1109/CYCONUS.2017.8167501
[39] B. Wang, X. Li, L.P. de Aguiar, D.S. Menasche, Z. Shafiq, Characterizing and modeling patching practices of industrial control systems, in: ACM Sigmetrics, 2017, pp. 1–23. https://doi.org/10.1145/3084455
[40] C. Xiao, A. Sarabi, Y. Liu, B. Li, M. Liu, T. Dumitras, From patching delays to infection symptoms: using risk profiles for an early discovery of vulnerabilities exploited in the wild, in: USENIX Security, 2018.
[41] Z. Zhu, T. Dumitras, ChainSmith: automatically learning the semantics of malicious campaigns by mining threat intelligence reports, in: EuroS&P, 2018, pp. 458–472. https://doi.org/10.1109/EuroSP.2018.00039
[42] M. Almukaynizi, E. Nunes, K. Dharaiya, M. Senguttuvan, J. Shakarian, P. Shakarian, Patch before exploited: an approach to identify targeted software vulnerabilities, in: AI in Cybersecurity, Springer Intelligent Systems Reference Library, Springer, Switzerland, 2019, pp. 81–113. https://doi.org/10.1007/978-3-319-98842-9_4
[43] Á.J. Varela-Vaca, D. Borrego, M.T. Gómez-López, R.M. Gasca, A.G. Márquez, Feature models to boost the vulnerability management process, J. Syst. Softw. 195 (2023) 111541. https://doi.org/10.1016/j.jss.2022.111541
[44] T.H.M. Le, et al., A survey on data-driven software vulnerability assessment and prioritization, CSUR (2021). https://doi.org/10.1145/3529757
[45] O. Suciu, C. Nelson, Z. Lyu, T. Bao, T. Dumitraş, Expected exploitability: predicting the development of functional vulnerability exploits, in: 31st USENIX Security Symposium, 2022, pp. 377–394.
[46] M.R. Shahid, H. Debar, CVSS-BERT: explainable natural language processing to determine the severity of a computer security vulnerability from its description, in: ICMLA, IEEE, 2021, pp. 1600–1607. https://doi.org/10.1109/ICMLA52953.2021.00256

Supplementary Material for "Cream Skimming the Underground: Identifying Relevant Points in TI Feeds and Online Forums"

Kajal Patel[a], Mateus Nogueira[b], Zubair Shafiq[a], Enrico Lovat[d], Taimur Kashif[a], Ashton Woiwood[f], Matheus Martins[e], Felipe Moreno-Vera[c], Miguel Bicudo[b], Cainã Figueiredo[b], Cabral Lima[b], Gaurav Srivastava[d], Anton Kocheturov[d], Leandro Pfleger de Aguiar[d], Daniel Menasché[b]

[a] *University of California, Davis, CA, United States*
[b] *Federal University of Rio de Janeiro, Rio de Janeiro, RJ, Brazil*
[c] *Getulio Vargas Foundation, Rio de Janeiro, RJ, Brazil*
[d] *Siemens, Princeton, NJ, United States*
[e] *Siemens, Amadora, LX, Portugal*
[f] *University of Iowa, Iowa City, IA, United States*

Abstract

This document collects material on threat intelligence (TI) feeds that was partially reported in [1]. It contains the full characterization of the 191 TI feeds (Section S1), the details of the labeling procedure and feature extraction (Section S2), the previously reported classification results, including temporal, temporal+spatial, and feature-ablation analyses and a discussion of applications of TIBERT (Section S3), a t-SNE visualization of static embeddings (Section S4), an example TI event (Section S5), and a description of the providers of the top-10 feeds (Section S6).

S1. TI Feed Characterization

This section expands Section 2.1 of the main manuscript.

We study the TI feeds in our dataset in terms of their *Indicators of Compromise* (or IoCs) categories together with their temporal and spatial properties. Every TI feed holds a list of *events*, and every event bundles a set of IoCs.

Table S1: Statistics of top-10 TI feeds ranked based on IoC count [1].

Provider	Event count	IoC count	Average number of IoCs per event	Average event timespan (days)	Dominant IoC category (%)	Dominant event tag (%)
Feed 1	644	276,481	429.3	1.77	network activity (69.65%)	misp-galaxy:tool="emotet" (11.89%)
Feed 2	1,234	165,292	133.9	45.86	network activity (43.35%)	type:osint (11.30%)
Feed 3	130	139,852	1,075.8	21.29	network activity (84.43%)	osint:source-type="block-or-filter-list" (11.96%)
Feed 4	6,955	52,803	7.6	0.72	network activity (98.51%)	circl:incident-classification="malware" (51.04%)
Feed 5	120	48,952	407.9	90.62	network activity (84.73%)	type:osint (28.01%)
Feed 6	230	27,376	119.0	14.12	network activity (56.62%)	osint:source-type="blog-post" (18.41%)
Feed 7	1,623	16,056	9.9	0.09	external analysis (100%)	njrat (30.04%)
Feed 8	613	15,953	26.0	0.00	network activity (82.94%)	malware:emotet (33.30%)
Feed 9	138	14,028	101.7	99.85	payload delivery (81.10%)	misp-galaxy:ransomware="locky" (29.91%)
Feed 10	55	11,448	208.1	49.62	payload delivery (68.52%)	malware_classification:malware-category="trojan" (13.90%)
Other feeds	2256	98,305	6.6	4.32	network activity (45.98%)	unstructured (6.22%)

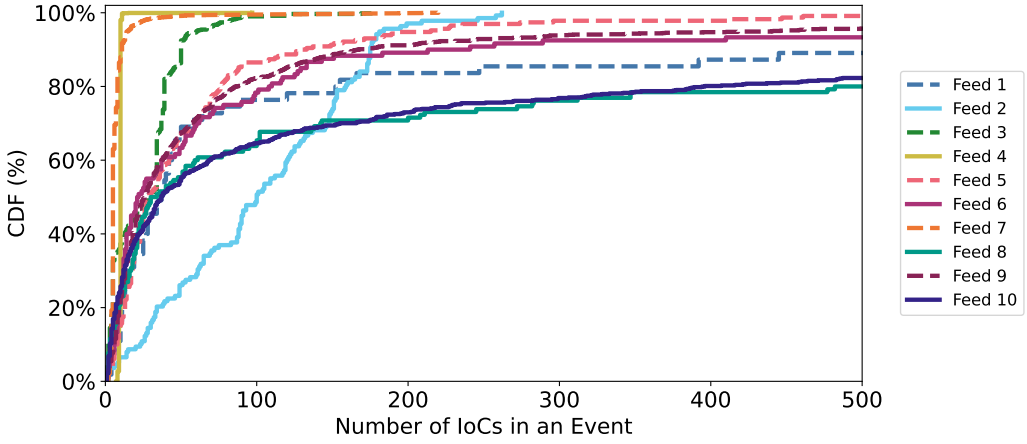


Figure S1: CDF of the number of IoCs per event for the top-10 feeds, restricted to the range 0–500 IoCs. Most events contain few IoCs, while a minority contain many [1].

S1.1. Dataset of TI feeds

Our dataset gathers 191 TI feeds from public and private providers. Altogether, it spans roughly 14 thousand events and 866,541 IoCs over 2013–2019. An event might be a security incident—a phishing attack, a botnet attack—or a security advisory about a software vulnerability. Each event carries timestamps marking when it was created and last modified. The IoCs inside an event are likewise timestamped individually. The *event timespan* is the gap, in days, between the latest and the earliest IoC timestamps of that event. Every IoC comes with a comment field holding a free-form textual description and an IoC category. An event may also include a comment field that usually captures the analyst's assessment. The IoCs, comments,

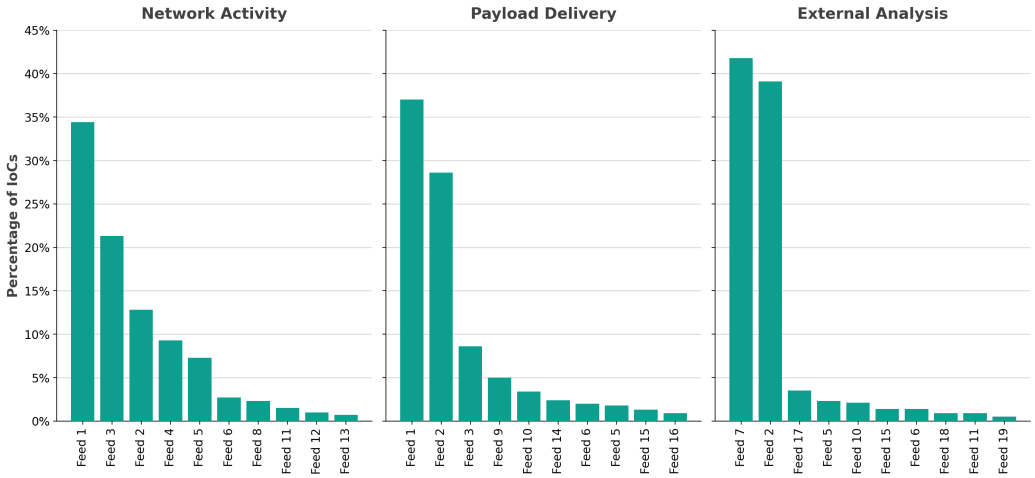


Figure S2: Contribution of TI feeds to popular IoC categories [1].

and timestamps together make up the *attributes* of an event. Beyond these attributes, an analyst may assign *tags* to an event, following standardized taxonomies. An event tagged *tlp:white*, for example, may be shared with the general public under the Traffic Light Protocol (TLP) [2], whereas an event tagged *type:osint* holds Open Source Intelligence (OSINT) [3].

Table S1 reports statistics for the top-10 TI feeds ranked by IoC count. The biggest source is Feed 1, a government organization, with 276,481 IoCs at an average of 429 IoCs per event. Per-event IoC counts range over several orders of magnitude: some feeds, like Feed 3, average more than a thousand IoCs per event, while others, like Feed 4, average fewer than ten. The CDFs in Figure S1 show that these averages can mislead, since even feeds with high averages are dominated by small events. Each of the top-10 feeds has at least 70% of its events with no more than 200 IoCs, and every feed except Feed 2 has at least 60% of its events with no more than 100 IoCs.

S1.2. IoC categories

Feed vendors sort each IoC into one of several self-reported categories; we do not assume that feeds follow the same categorization procedure. As Table S1 shows, most popular feeds consist chiefly of network activity IoCs (IP addresses, hostnames, domains, URLs), while others center on payload delivery (filenames, hashes, malware samples) or external analysis (textual analyses by experts and links to other organizations).

Figure S2 shows how much individual feeds contribute to each popular category. The three categories that together account for 87% of all IoCs show a lopsided contribution. Network activity leads with 557,532 IoCs, more than half of which come from Feed 1 and Feed 3. Payload delivery follows with 220,321 IoCs, of which Feed 1 and Feed 2 each supply about 30%. External analysis trails with 38,531 IoCs, with Feed 7 and Feed 2 each providing close to 40%.

All but one feed have a majority of events with at least one commented IoC. On average, 67.7% of IoCs carry a comment, with an average length of 27.7 characters. We distinguished three kinds of comments: descriptions of an attack, descriptions of the IoC format, and logistical upload information. For instance, one IoC carried the comment "Kill switch domain. Monitor, do not block. (Source: Cisco Umbrella)"; another, "RAT name", indicating that the IoC names a remote access trojan; and a third, "This attribute has been automatically imported." Such comments offer context that can guide incident response and prioritization.

S1.3. Temporal analysis

The average event timespan varies substantially across feeds (Table S1). Some feeds, such as Feed 1, have average timespans under a couple of days, whereas others, such as Feed 5, reach about three months. Feed 4 and Feed 7 average less than a day, and Feed 8 averages zero, i.e., all IoCs of each of its events share the same timestamp. Figure S3 shows the distributions: 9 of the top-10 feeds have at least 70% of their events with timespans of at most 4 days, while Feed 2 stands apart, with fewer than 30% of its events spanning less than 30 days.

S1.4. Spatial analysis

We measure redundancy across feeds as IoC overlap, restricted to IP addresses and hashes. Overlap is highly uneven (Figure S4). Feed 8 shares fewer than four IoCs with all but one of the other top feeds. Feed 2 shares more than 250 IoCs with six other top feeds—more than 900 with Feed 6 and 1000 with Feed 10—while Feed 1 shares over 200 IoCs each with Feed 2 and Feed 3 and more than 1700 with Feed 6. Such overlap mirrors earlier findings on IP blocklists [4, 5].

Overlap disregards timing, so we also study which feed publishes a shared IoC first (Figure S5). Some feeds behave chiefly as sources: Feed 1 publishes first for about 84.8% of the IoCs it shares. Others behave as sinks: Feed 6

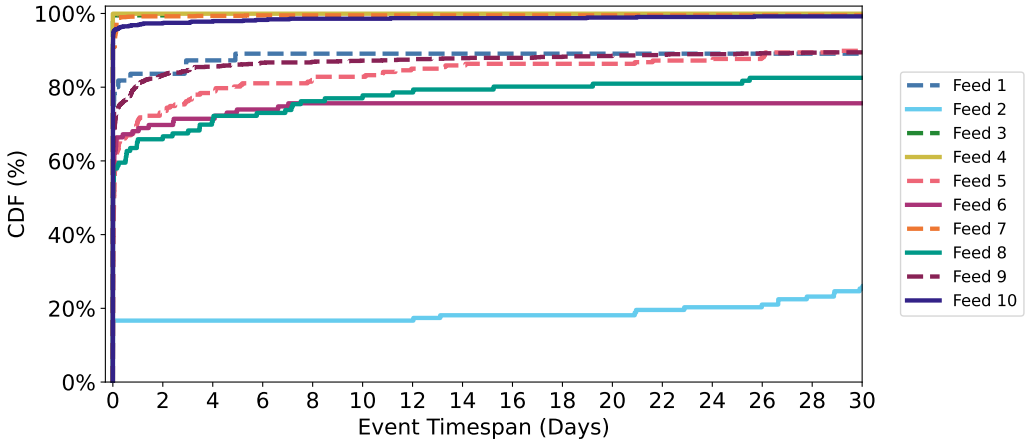


Figure S3: CDFs of the event timespan for the top-10 feeds.

largely takes in IoCs already seen in Feed 1 and Feed 2. Others balance both roles; Feed 2, for example, publishes first for 68% of its shared IoCs.

Takeaways. TI feeds hold varied information about diverse threats in a loosely structured format; their content is updated dynamically, often over long periods; and feeds complement one another while also carrying redundant information.

S2. Labeling and Feature Extraction Details

This section expands Section 3 of the main manuscript.

S2.1. Problem statement and relation to EPSS

Our target is to classify TI feed events that report exploitation of security vulnerabilities. The task is related to, yet distinct from, vulnerability weaponization (whether an exploit exists) [6, 7, 8]: weaponization can be established in a controlled setting, while exploitation requires observations in the wild.

The Exploit Prediction Scoring System (EPSS) estimates the probability that a disclosed vulnerability will be exploited in the wild over a given horizon, usually 12 months. Its regression model weighs factors such as vendor reputation, the public availability of proof-of-concept exploits, and

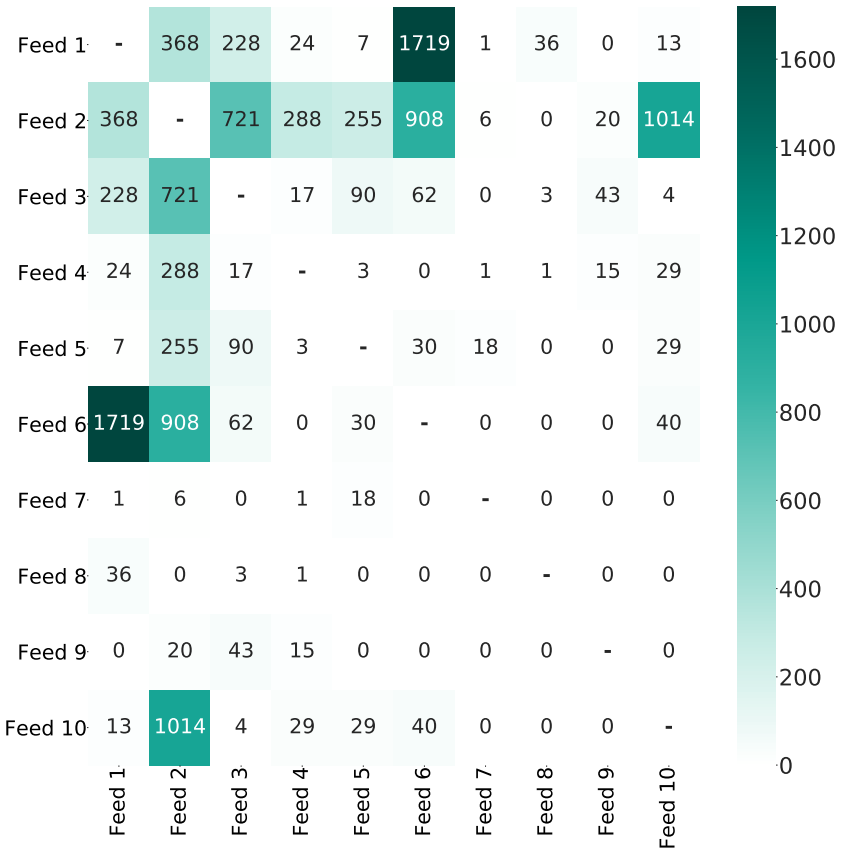


Figure S4: IoC overlap across top-10 TI feeds, considering only hashes and IPs. Some feeds, in particular Feed 2, share IoCs with several others [1].

vulnerability characteristics including severity, complexity, and related attacks. EPSS is calibrated on historical exploitation records, which lets security teams prioritize patching when resources are limited. Observed exploitation events supply exactly the kind of ground truth behind such scores: once an event is classified as exploitation, the vulnerabilities involved become candidates for revised CVSS or EPSS scores, closing a feedback loop that improves later predictions. Our goal is thus to classify events as *exploitation* or *non-exploitation*.

S2.2. Manual labeling by experts

We first select events whose descriptions, comments, or IoC attributes reference specific CVE identifiers. Two independent experts label them; the

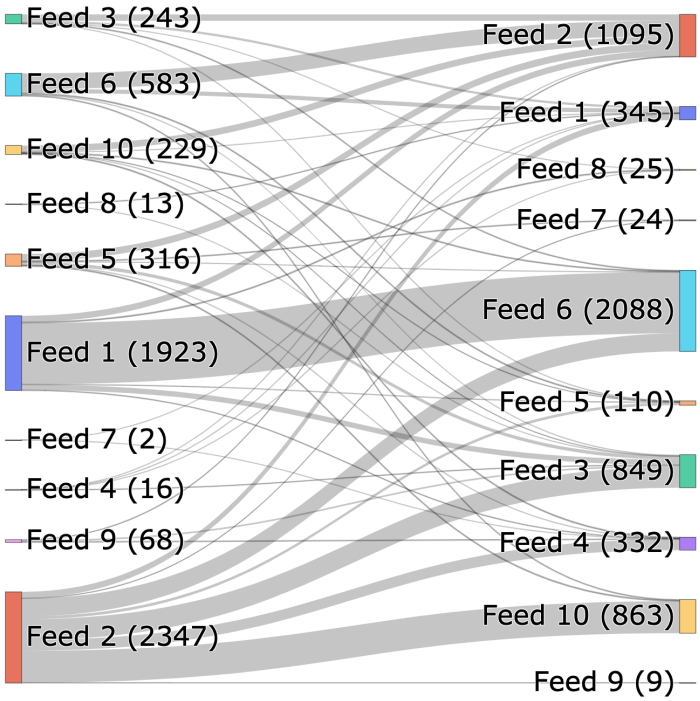


Figure S5: Flow of common IoCs across top-10 TI feeds. The left side shows counts of IoC sources and the right side the counts of IoC sinks [1].

data are partitioned between the experts except for 10% that both label. On this overlap, Cohen's kappa is 0.89, which corresponds to strong agreement [9], so we treat the remaining labels as reliable.

An event is labeled exploitation when it: (1) carries a clearly malicious element such as an Advanced Persistent Threat (APT), a Distributed Denial of Service (DDoS), or a trojan attack; (2) belongs to a known malicious campaign; (3) references a known hacker group or organization; or (4) includes keywords such as espionage or campaign in an appropriate context. The illustrative event in the appendix of main paper satisfies criteria (2), (3), and (4). An event is labeled non-exploitation when it: (1) is an update to existing software without a malicious element; (2) includes keywords such as patch, update, or reset in an appropriate context; (3) shows no clear sign of malicious activity; or (4) provides too little or too ambiguous information. Four thousand events were labeled this way.

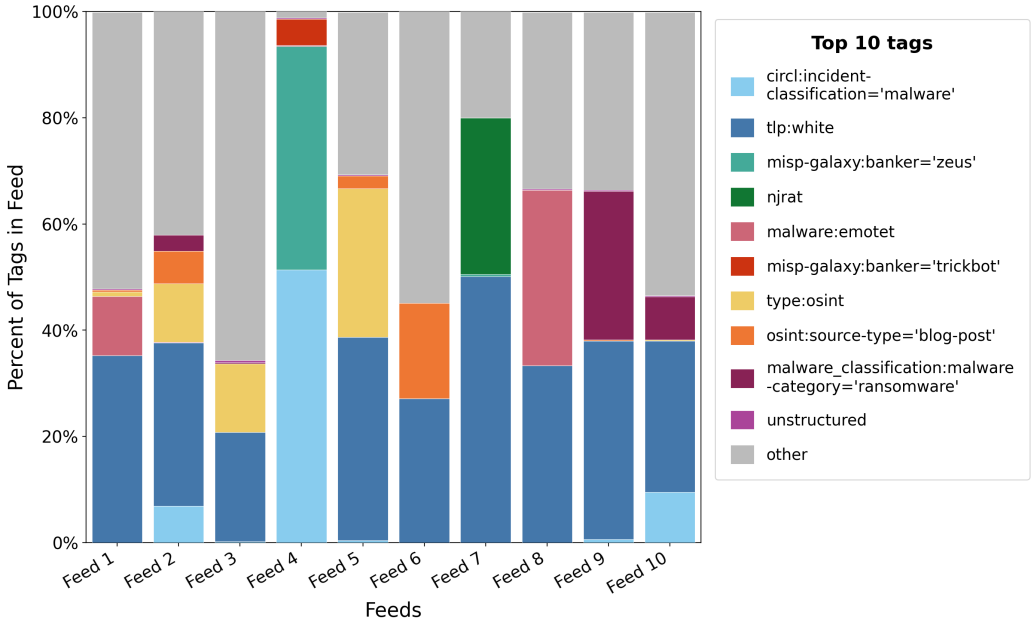


Figure S6: Breakdown of most common tags throughout top-10 feeds [1].

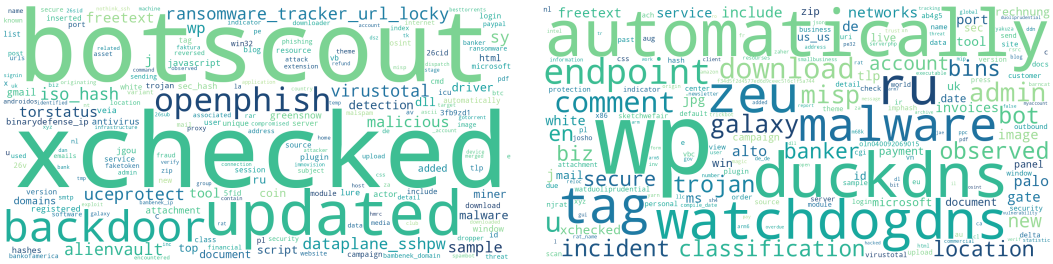
S2.3. Event tags

Events can carry one or more MISP machine tags [10] of the form "*namespace:predicate=value*", e.g., "*misp-galaxy:threat-actor=Sofacy*" and "*tlp:white*". Tags follow shared taxonomies, are assigned manually, and are meant to be consumed by downstream systems such as intrusion detection systems. Manual tagging may reflect analyst bias and is labor-intensive, but it also eases quality control. Since every event in our dataset has at least one tag, tags provide a baseline for classification.

Figure S6 shows, per feed, the share of each tag type. In most feeds an event carries 2–3 tags. Tags recurring across feeds include circl:incident-classification="malware", malware:emotet, type:osint, and malware_classification:malware-category="ransomware".

Automated labeling based on event tags

To extend the ground truth beyond the four thousand manually labeled events, we mined association rules between tags and exploitation with the apriori algorithm [11] (support ≥ 0.001, confidence ≥ 0.5, lift ≥ 1), obtaining roughly 735 rules, after removing unrelated tags such as `tlp`. The remain-



(a) Exploitation events (b) Non-exploitation events

Figure S7: Word clouds of exploitation and non-exploitation events.

ing ten thousand events were labeled *exploitation* exactly when all tags of at least one rule were present, and *non-exploitation* otherwise. For example, apriori produced the rule `sectorfinancial` & `kill-chain:delivery` & `kill-chain:command and control` → **Exploitation**.

Label distribution

In the top-10 feeds, 11% of events are labeled exploitation, with large differences across feeds: about 89% of the events of Feed 3 and 87% of those of Feed 10 are exploitation, whereas Feed 4, Feed 7, and Feed 8 contain none. Across all feeds, 82% of events are non-exploitation and 18% exploitation.

S2.4. Longitudinal evaluation

Because exploitation detection is an arms race, models must be evaluated longitudinally. In *temporal* splits, the data are divided into 11 windows with the same number of events, and the model is always tested on the next window. Under the *aggregate-window* split it is trained on all preceding windows, so training data grow over time; under the *equal-window* split it is trained only on the immediately preceding window, so training size is constant. This lets us assess the effects of data volume and recency. In *temporal+spatial* splits, the test set is restricted to a single feed whose events are excluded from all training windows. For example, with Feed 2 held out, no training set contains Feed 2 events and the test set contains only Feed 2 events.

S2.5. Features

Figure S7 visualizes frequent terms in both classes. Exploitation events are often followed by updates described in the event text, hence the frequency

of 'updated'; the illustrative event in the main paper, for instance, has "Update" in its info field and reports an espionage app. Detection sources, such as 'botscout' or 'uceprotect', also appear. Non-exploitation events tend to concern advisories, weaponization, or vulnerabilities without real-world impact; for example, WordPress-related advisories explain the term 'wp', and 'watchdog' timers appear in sandbox reports. The presence of a word does not by itself determine the class, since context is decisive.

Pre-processing and feature extraction

Text is split on special characters and stop words are removed. Hashes, which rarely transfer across feeds because malware can polymorphically change its signature, are replaced by an abstract token. We then consider Doc2Vec [12], which maps each word to a context-independent vector, and BERT [13] (BERT-base-uncased via BERT-as-Service [14]), which produces context-dependent vectors. TI2Vec is Doc2Vec trained without supervision on the 191-feed corpus for 15 epochs. TIBERT is obtained by fine-tuning BERT-base-uncased for sequence classification on our TI dataset for 10 epochs, with an added classification layer.

Supervised classification

To limit overfitting, Doc2Vec features are restricted to $n = 1000$ dimensions, and BERT produces 768-dimensional vectors. We train Naive Bayes and Decision Tree classifiers, which handle non-linearly separable classes; since features are interdependent (Section S1), Decision Trees are expected to fit better than Naive Bayes. We also use AdaBoost, which combines many shallow trees. TIBERT uses its own classification head, learning representation and classification jointly.

S3. Previously Reported Classification Results

This section expands Section 4.1 of the main manuscript.

We report F1 scores because of class imbalance (82% non-exploitation); precision and recall show similar trends.

S3.1. Impact of feature extraction

Table S2 summarizes results under equal-window splits. TIBERT achieves the highest average F1 (78%), improving on TI2Vec by about 4 percentage points. Both domain-adapted models outperform their generic counterparts,

Table S2: Temporal classification accuracy (F1 scores) results of different features and classifiers using equal window temporal splits [1].

Split ID	Approach									
	Doc2Vec			TI2Vec			BERT Embeddings			TIBERT
	Naive Bayes	Decision Tree	Ada Boost	Naive Bayes	Decision Tree	AdaBoost	Naive Bayes	Decision Tree	Ada Boost	
2	0.93	0.64	0.86	0.9	0.75	0.83	0.68	0.63	0.75	0.72
3	0.87	0.81	0.72	0.82	0.87	0.83	0.8	0.75	0.78	0.92
4	0.69	0.50	0.55	0.37	0.68	0.74	0.36	0.44	0.33	0.83
5	0.06	0.55	0.75	0.5	0.81	0.83	0.79	0.75	0.83	0.89
6	0.57	0.47	0.64	0.6	0.63	0.65	0.42	0.49	0.57	0.69
7	0.49	0.46	0.67	0.59	0.6	0.67	0.67	0.58	0.63	0.66
8	0.60	0.60	0.74	0.49	0.7	0.75	0.58	0.67	0.75	0.78
9	0.32	0.40	0.64	0.53	0.61	0.65	0.57	0.63	0.61	0.65
10	0.51	0.76	0.74	0.46	0.49	0.68	0.54	0.54	0.74	0.84
Average	0.56	0.58	0.70	0.58	0.68	0.74	0.60	0.61	0.67	0.78

which we attribute to training on a large IoC-rich corpus that covers multiple feeds.

S3.2. Impact of classifier

Among the classifiers used with features other than TIBERT, AdaBoost outperforms Naive Bayes and Decision Tree. The Decision Tree favors precision and Naive Bayes favors recall, whereas AdaBoost balances both, improving F1 over the Decision Tree by 12 percentage points with Doc2Vec and by 6 percentage points with TI2Vec and BERT.

S3.3. Impact of temporal splits

Figure S8 shows TIBERT F1 scores under equal- and aggregate-window splits. Under aggregate windows, F1 does not increase monotonically: it rises, drops sharply at split 4, and recovers as training data grow. The drop coincides with a large vocabulary shift, as the test set of split 4 contains about 44,000 distinct words absent from training. Overall, equal windows perform better (average F1 of 78% vs. 63%), suggesting that recency matters more than volume.

S3.4. Impact of TI feed

Figure S9 shows F1 scores when each feed is held out from training and used as the only test feed, under aggregate-window split 7, for feeds with at least one exploitation event in the test set. Results correlate with the flow analysis of Figure S5: feeds acting mostly as sinks yield higher F1 when held

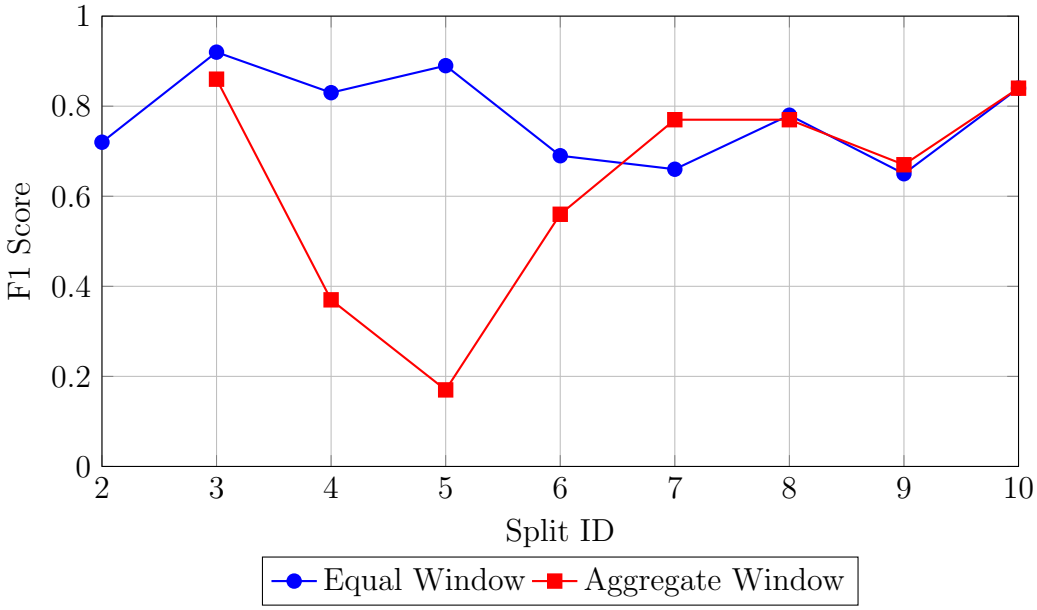


Figure S8: TIBERT F1 scores across temporal splits for equal and aggregate window strategies [1].

out. Holding out Feed 6, which has the most sink Hash and IP IoCs (2088), gives F1 of 89%, and Feed 2, second with 1095, is among the four best. Holding out Feed 1, which acts as a source for about 85% of its overlapping IoCs (Figure S4), gives only 45%. An exception is Feed 5, mostly a source yet yielding 92%, possibly because it shares similar rather than identical IoCs with other feeds. Transfer to unseen feeds thus depends on how similar their IoCs are to those in training.

S3.5. Feature ablation

Using a single IoC category, F1 is 40% for network activity, 39% for payload delivery, and 66% for external analysis; combining all categories yields 78%. Although categories contribute unequally, they complement one another.

S3.6. Applications of TIBERT

Exploitation events predicted by TIBERT can update temporal exploitability metrics of CVSS/EPSS related to the availability of proof-of-concept or functional exploits. For example, the *Exploit Code Maturity* metric could be

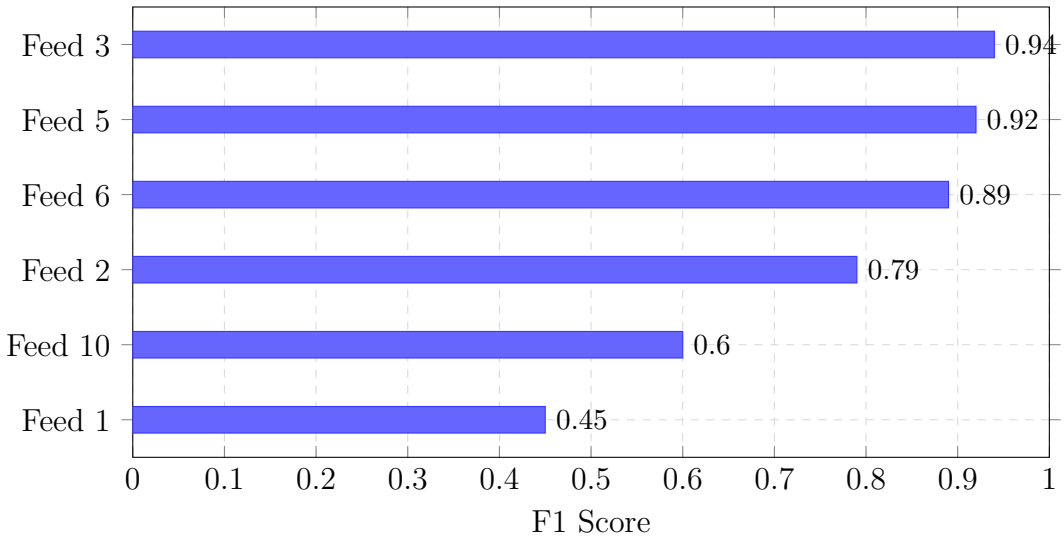


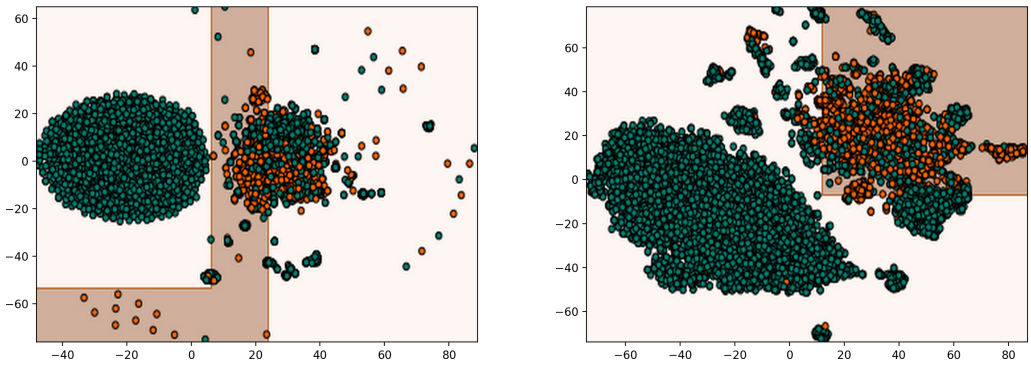
Figure S9: TIBERT F1 scores when each TI feed is omitted from training under the temporal+spatial aggregate window split 7 [1]. Feed 9 is excluded because it contains only five exploitation events.

revised from "Proof of concept code" to "Functional exploit exists", saving analyst effort.

With an average F1 of 0.78, false positives and false negatives are unavoidable. A false positive can prompt untimely patching, causing transient unplanned unavailability, added cost, and misprioritization; a false negative can leave an exploited vulnerability unnoticed. Since TIBERT is meant to update scores rather than replace them, these risks are mitigated. In our configuration, TIBERT's false positive rate (1%) is half its false negative rate (2%). Moreover, the affected temporal metrics are only a few among many metrics in CVSS, so errors in them have limited impact on the overall score.

S4. Visualization of Doc2Vec and TI2Vec Embeddings

Figure S10 shows t-SNE projections of Doc2Vec and TI2Vec event embeddings, with non-exploitation events in green and exploitation events in red. Both produce distinguishable clusters, but TI2Vec separates them more clearly. A two-level decision tree trained on the projections achieves F1 of 55% (Doc2Vec) and 66% (TI2Vec), consistent with the averages of 58% and



(a) (b)

Figure S10: (a) Doc2Vec and (b) TI2Vec embeddings (t-SNE) with decision-tree boundaries; TI2Vec is roughly 10 percentage points better in F1 [1].

68% in Table S2; the slight decrease is expected given the lossy projection and the shallow trees. Accuracy remains around 84% in all variations.

References

[1] K. Patel, Z. Shafiq, M. Nogueira, D. Menasché, E. Lovat, T. Kashif, A. Woiwood, M. Martins, Harnessing TI Feeds for Exploitation Detection, in: 2024 IEEE International Conference on Cyber Security and Resilience (CSR), IEEE, 2024, pp. 200–207. doi:10.1109/CSR61664.2024.10679417.

[2] FIRST.org, Traffic Light Protocol, `https://www.first.org/tlp/`, Last Accessed: 2025-01-15.

[3] IBM, What is open source intelligence (OSINT)?, `https://www.ibm.com/think/topics/osint`, Last Accessed: 2026-07-17.

[4] V. G. Li, M. Dunn, et al., Reading the Tea Leaves: A Comparative Analysis of Threat Intelligence, in: USENIX Security, USENIX, Santa Clara, 2019, pp. 851–867. doi:10.5555/3361338.3361398.

[5] S. Ramanathan, J. Mirkovic, M. Yu, BLAG: Improving the Accuracy of Blacklists, in: NDSS, Internet Society, San Diego, CA, 2020, pp. 1–15.

[6] S. Frei, M. May, U. Fiedler, B. Plattner, Large-Scale Vulnerability Analysis, in: SIGCOMM workshop on Large-scale attack defense, ACM, Pisa, Italy, 2006, pp. 131–138.

[7] M. Bozorgi, L. K. Saul, S. Savage, G. M. Voelker, Beyond Heuristics: Learning to Classify Vulnerabilities and Predict Exploits, in: KDD, ACM, Washington, DC, 2010, pp. 105–114.

[8] M. Shahzad, M. Z. Shafiq, A. X. Liu, Large scale characterization of software vulnerability life cycles, IEEE Transactions on Dependable and Secure Computing 17 (4) (2019) 730–744.

[9] J. Cohen, A coefficient of agreement for nominal scales, Educational and psychological measurement 20 (1) (1960) 37–46.

[10] MISP, MISP taxonomies and classification as machine tags, `https://www.circl.lu/doc/misp-taxonomies/`, Last Accessed: 2025-01-15.

[11] R. Srikant, Fast algorithms for mining association rules and sequential patterns, The University of Wisconsin-Madison, 1996. doi:10.5555/924822.

[12] Q. Le, T. Mikolov, Distributed representations of sentences and documents, in: ICML, PMLR, 2014, pp. 1188–1196. doi:10.5555/3044805.3045025.

[13] J. Devlin, M.-W. Chang, K. Lee, K. Toutanova, Bert: Pre-training of deep bidirectional transformers for language understanding, in: NAACL-HLT, 2019, pp. 4171–4186. doi:10.18653/v1/N19-1423.

[14] H. Xiao, bert-as-service, `https://pypi.org/project/bert-serving-server/`, Last Accessed: 2025-03-15 (2018).